Informe de Auditoría de Seguridad - INSECUR S.A.

TryHackMe: Basic Pentesting

Autora: Maria Emilia Ortiz Sosa
Institución: Universidad Champagnat
Carrera: Licenciatura en Sistemas de Información
Fecha: 13 de Octubre de 2026

---

1. Resumen Ejecutivo

El presente documento detalla la auditoría de seguridad y prueba de penetración realizada sobre los servidores objetivo asignados (IP: 10.65.131.110 para Basic Pentesting e IP: 10.67.157.58 para la instancia Kenobi corriendo Linux Ubuntu 20.04.6 LTS / Kernel 5.15), correspondientes a las salas de evaluación de la plataforma TryHackMe. Durante la evaluación, se identificaron vulnerabilidades críticas de exposición de información, servicios desactualizados vulnerables a CVE-2015-3306 y configuraciones débiles de contraseñas y binarios SUID que permitieron comprometer totalmente los sistemas objetivo y obtener acceso root.

---

2. Metodología y Fases del Ataque

La auditoría se llevó a cabo siguiendo las fases estándar de un proceso de pentesting:

Fase 1: Reconocimiento e Identificación de Servicios

Se ejecutaron escaneos de puertos utilizando Nmap sobre los objetivos. En la instancia Kenobi (10.67.157.58) se detectaron 7 puertos TCP abiertos (H-02): 21/TCP (ProFTPD 1.3.5), 22/TCP (OpenSSH 8.2p1), 80/TCP (Apache httpd 2.4.41), 111/TCP (RPCBind 2-4), 139/TCP y 445/TCP (Samba smbd 4), y 2049/TCP (NFS 3-4).

Posteriormente, se empleó Gobuster para realizar enumeración web en el servidor Apache, descubriendo un directorio oculto denominado /development/.

Fase 2: Análisis de Vulnerabilidades (Fuga de Información)

En la auditoría web inicial, el acceso al directorio /development/ reveló archivos con notas internas que expusieron usuarios y políticas débiles. Adicionalmente, durante la enumeración de la instancia Kenobi, se descubrieron 3 recursos compartidos de Samba (print$, anonymous e IPC$). Tras inspeccionar el archivo log.txt del recurso anonymous, se identificó la versión vulnerable de ProFTPD 1.3.5 (afectada por CVE-2015-3306 en el módulo mod_copy).

Fase 3: Explotación (Acceso Inicial)

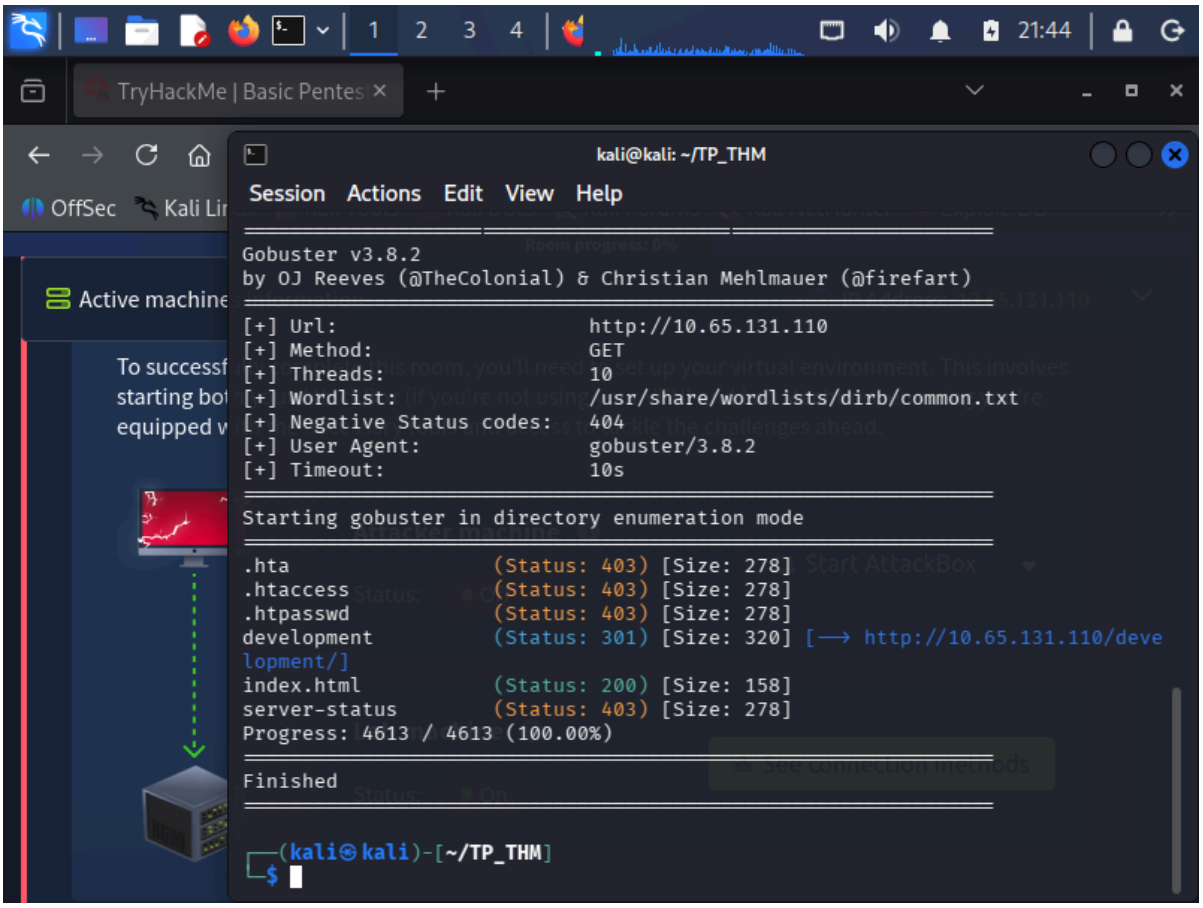
Mediante la explotación de CVE-2015-3306 en ProFTPD, se ejecutaron comandos no autenticados SITE CPFR y SITE CPTO para copiar la clave privada SSH (/home/kenobi/.ssh/id_rsa) a /var/tmp/id_rsa. Luego, mediante el montaje NFS del directorio exportado /var (sudo mount 10.67.157.58:/var carpeta/), se extrajo la clave id_rsa, logrando un acceso inicial vía SSH como el usuario kenobi. En paralelo, en el servidor básico se obtuvo acceso mediante fuerza bruta vía Hydra.

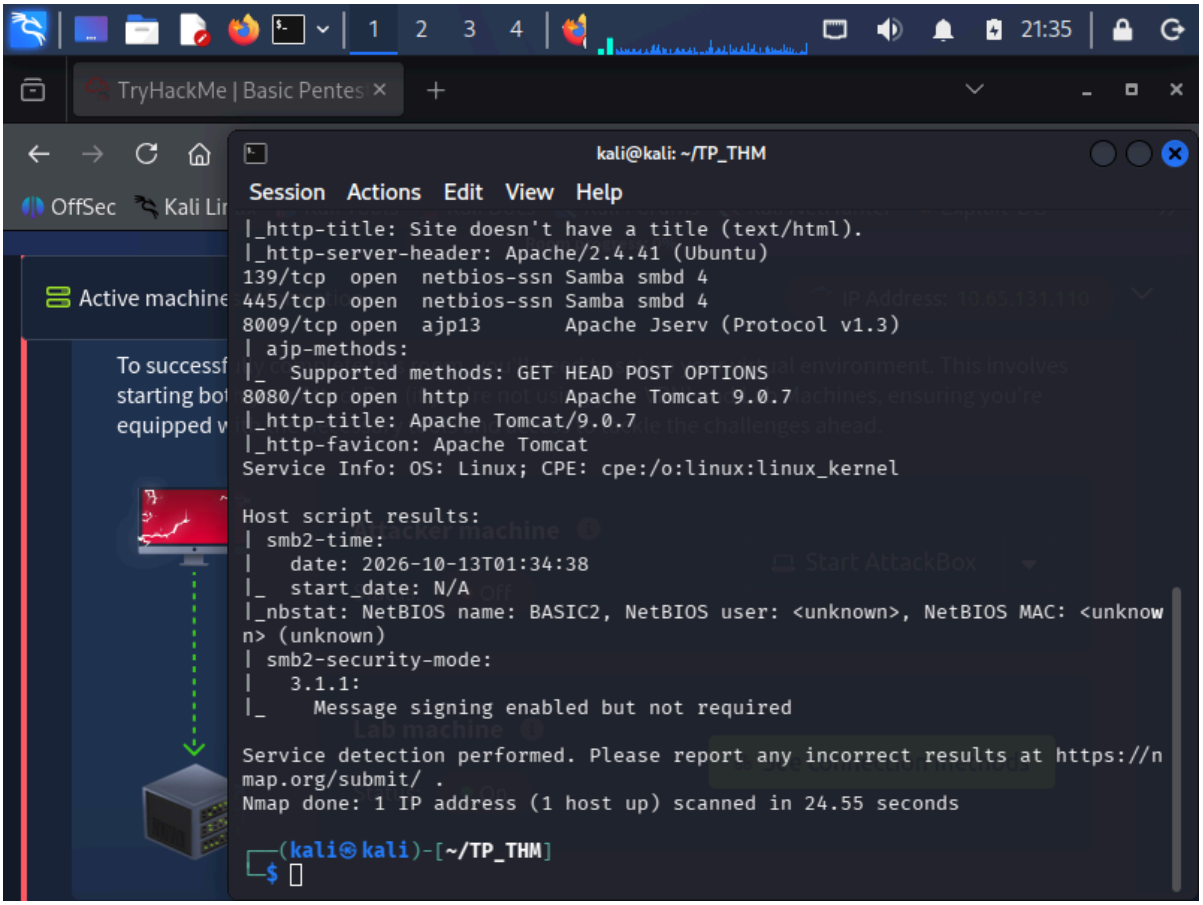
Fase 4: Escalada de Privilegios

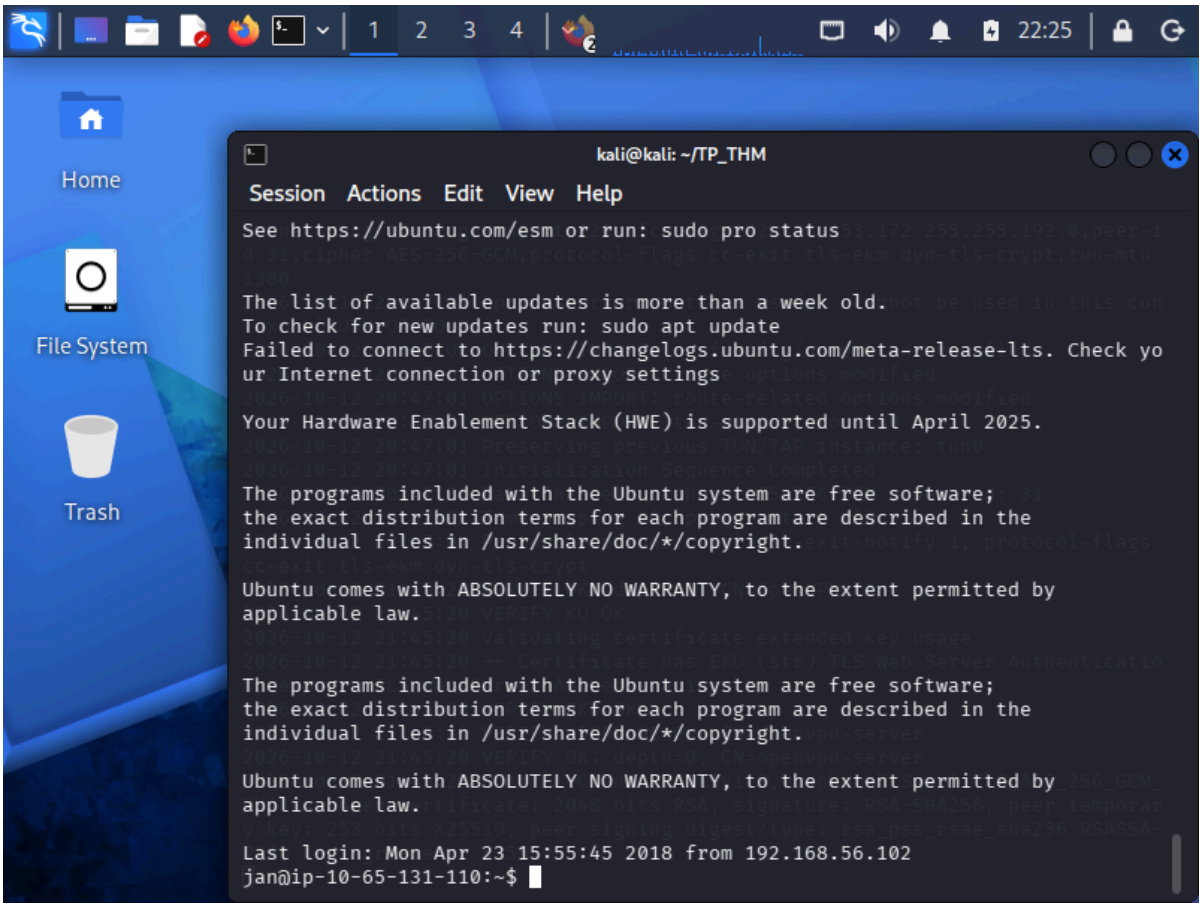
En el servidor Kenobi, la enumeración de binarios SUID permitió identificar el ejecutable anómalo /usr/bin/menu. Explotando la manipulación de la variable de entorno $PATH, se creó un script ejecutable malicioso denominado curl apuntando a /bin/sh. Al invocar la opción 3 del menú con la variable $PATH modificada, se logró escalar privilegios con éxito y obtener una shell interactiva como usuario root.

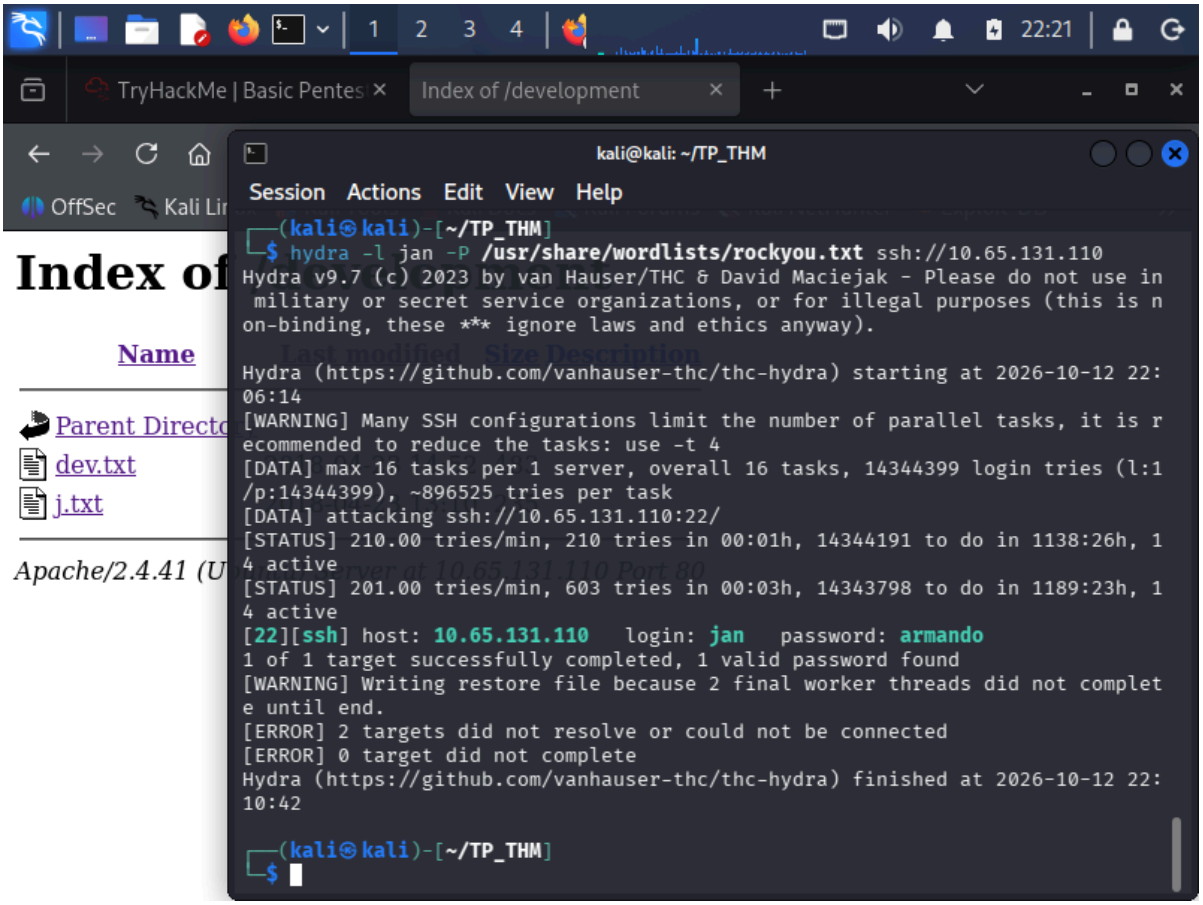
---

3. Registro de Evidencias




21:35
TryHackMe | Basic Pentes
OffSec
Kali Lir
Active machine
To successf
starting bo
equipped v
kali@kali: ~/TP_THM
Session Actions Edit View Help
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp open netbios-ssn Samba smbd 4
445/tcp open netbios-ssn Samba smbd 4
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
| ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp open http Apache Tomcat 9.0.7
|_http-title: Apache Tomcat/9.0.7
|_http-favicon: Apache Tomcat
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
Host script results:
| smb2-time:
| date: 2026-10-13T01:34:38
|_ start_date: N/A
|_nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknow
n> (unknown)
| smb2-security-mode:
| 3.1.1:
|_ Message signing enabled but not required
Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.55 seconds
(kali㉿kali)-[~/TP_THM]
$


22:25
Home
File System
Trash
kali@kali: ~/TP_THM
Session Actions Edit View Help
See https://ubuntu.com/esm or run: sudo pro status
The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check yo
ur Internet connection or proxy settings
Your Hardware Enablement Stack (HWE) is supported until April 2025.
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
Last login: Mon Apr 23 15:55:45 2018 from 192.168.56.102
jan@ip-10-65-131-110:~$


TryHackMe | Basic Pentes
Index of /development
Index of
Name
Parent Directo
dev.txt
j.txt
Apache/2.4.41 (U
kali@kali: ~/TP_THM
Session Actions Edit View Help
(kali㉿kali)-[~/TP_THM]
$ hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.65.131.110
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-12 22:06:14
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.65.131.110:22/
[STATUS] 210.00 tries/min, 210 tries in 00:01h, 14344191 to do in 1138:26h, 14 active
[STATUS] 201.00 tries/min, 603 tries in 00:03h, 14343798 to do in 1189:23h, 14 active
[22][ssh] host: 10.65.131.110 login: jan password: armando
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-12 22:10:42
(kali㉿kali)-[~/TP_THM]
$


TryHackMe | Cyber Securi
tryhackme.com/room/pentestingfundamen
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB
¡Gran trabajo ortizemilia! Habitación completada!
¡Tus habilidades se están disparando!
Tareas completadas
5
Puntos ganados
72
Racha
1
Desplácese hacia abajo para revisar su progreso

- **Evidencia de escaneo:** Resultado del escaneo de puertos inicial.
- **Evidencia de directorio:** Descubrimiento de la carpeta oculta en el servidor web.
- **Evidencia de explotación:** Recuperación de la contraseña del usuario.
- **Evidencia de acceso:** Acceso exitoso vía SSH al servidor.

---

4. Recomendaciones de Seguridad (Mitigación)

Para subsanar las vulnerabilidades encontradas durante esta auditoría, se recomienda a la organización implementar las siguientes medidas:

1. **Políticas de Contraseñas:** Aplicar y forzar una política de contraseñas robustas en todos los servicios de autenticación (como SSH y SMB) que exija longitud mínima, complejidad y bloqueos tras intentos fallidos.
2. **Manejo de Información Sensible:** Eliminar inmediatamente cualquier archivo de texto, nota o respaldo con información interna de los directorios públicos del servidor web.
3. **Restricción de Permisos:** Configurar correctamente los permisos de archivos críticos en el sistema operativo para asegurar que información confidencial, como claves privadas, no pueda ser leída por usuarios no autorizados.
4. **Auditoría de Servicios Abiertos:** Evaluar la necesidad real de mantener expuestos los servicios SMB y Tomcat hacia redes externas, o implementar reglas estrictas de firewall.

5. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla:
Durante la fase de explotación (por ejemplo, al ejecutar ataques de fuerza bruta con Hydra o probar exploits), el servicio SSH o el servidor Apache Tomcat podrían sufrir una sobrecarga temporal o un bloqueo de puertos (denegación de servicio involuntaria), provocando la caída del sistema.

Impacto sobre la continuidad del negocio:
La caída del servidor interrumpiría los procesos de administración remota y el acceso a los aplicativos web internos de INSECUR S.A. El tiempo de inactividad afectaría la disponibilidad para los usuarios legítimos hasta que los servicios sean restablecidos.

Plan de respuesta:

1. **Activación:** Los sistemas de monitorización detectan la caída de los puertos 22, 80 o 8080 y envían una alerta automática al equipo de TI.
2. **Contención:** En los primeros 15 minutos, se suspenden temporalmente las pruebas de pentesting y se aísla la máquina afectada para evaluar si la caída fue producto de la auditoría o de un ataque real.
3. **Recuperación:** Se procede a reiniciar los demonios de los servicios afectados (`systemctl restart ssh tomcat`). Si existe corrupción, se realiza un rollback restaurando el último snapshot virtual del servidor.
4. **Comunicación:** Se notifica al director de TI y al cliente (INSECUR S.A.) sobre la interrupción controlada y el tiempo estimado de restauración.
5. **Post-mortem:** Tras recuperar el servicio, se documenta el incidente en la bitácora, se analizan los logs de saturación y se configuran límites de velocidad (rate limiting) en las herramientas de ataque para futuras pruebas.

RTO y RPO estimados:

- **RTO (Recovery Time Objective):** 4 horas (tiempo máximo tolerable para reiniciar servicios o restaurar la máquina virtual).
- **RPO (Recovery Point Objective):** 24 horas (los datos se restaurarían desde el backup de la noche anterior).

6. Anexos

Anexo A: Bitácora de comandos

Los comandos ejecutados se encuentran respaldados en el archivo de texto dentro del directorio `bitacora/` del repositorio, habiendo sido sanitizados para eliminar contraseñas y tokens.

Anexo B: Capturas de pantalla

Las evidencias visuales con las marcas de identidad correspondientes (usuario de TryHackMe, fecha/hora e IP) se ubican estructuradas por fase dentro del directorio `evidencias/` del proyecto.

Anexo C: Hashes de las flags obtenidas

- Flag Nivel 1 (Basic Pentesting): fac04da134507b42f2babaa1dc62d1cf18e8b91915bd05f4f7e4bc0571a44119 -

- Flag Nivel 2 (kenobi): 9c28680c60bda20ba001d979aa378c880670313074446a5ae0cc7b0d234daf18 (user.txt en /home/kenobi/user.txt)
- Flag Root (kenobi - root.txt): Valor: 177b3cd8562289f37382721c28381f02 | SHA-256: e593d6411516e038d1795db2f45145b23d5718a38a7c29be117ed26c044d0ec5

Anexo D: Declaración ética firmada
Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante: Maria Emilia Ortiz Sosa
Fecha: 13 de Octubre de 2026